

Contents

1	セキュリティ設計書 (メイン)	1
1.1	1. 文書概要	1
1.1.1	1.1 目的	1
1.1.2	1.2 対象範囲	2
1.1.3	1.3 版数	2
1.1.4	1.4 関連ドキュメント	2
1.2	2. セキュリティ基本方針	2
1.2.1	2.1 保護対象	2
1.2.2	2.2 想定脅威	2
1.2.3	2.3 基本対策方針	2
1.3	3. データ保護	2
1.3.1	3.1 PII 暗号化 (AES-256-GCM)+ オーナー派生 (共有概念正本 = メイン側)	2
1.3.2	3.2 保護層別方針	3
1.3.3	3.3 データ削除モード (物理削除 / 匿名化、§ 7.8 から移管)	3
1.3.4	3.4 お知らせ二層構成 (§ 7.7 から移管)	3
1.4	4. 入力値検証	4
1.5	5. Web 脆弱性対策	4
1.5.1	5.1 HTTP 応答ヘッダ (§ 10.5 から移管)	4
1.5.2	5.2 主要脅威別対策	4
1.5.3	5.3 お知らせ本文サニタイズ (2 重防御)	5
1.6	6. アクセス制御	5
1.7	7. 監査・ログ	5
1.7.1	7.1 ログ種別と保持目的 (§ 10.6 から移管)	5
1.7.2	7.2 メイン側の監査対象操作 (§ 10.6.5 から移管)	5
1.7.3	7.3 改ざん検知方式 (NFR-306)	6
1.7.4	7.4 エラーログ (error_logs)	6
1.8	8. 秘密情報管理 (共有概念正本 = メイン側)	6
1.8.1	8.1 暗号 管理 (§ 10.9 から移管)	6
1.8.2	8.2 ローテーション運用	6
1.8.3	8.3 ウィジェット API キー (projects/project_legacy_keys 、§ 8.3.4 から移管)	7
1.9	9. SaaS 特有のセキュリティ観点	7
1.10	10. 不正利用検知 (基本設計書 § 10.10 / FR-195 / NFR-308 = 共有概念正本)	7
1.10.1	10.1 検知・対応体系	7
1.10.2	10.2 検知パターン	8
1.11	11. メール配信信頼性・レピュテーション保護	8
1.11.1	11.1 メール配信信頼性 (NFR-501~507)	8
1.11.2	11.2 共通ドメインレピュテーション保護 (R-003 / FR-149b / NFR-504)	8
1.11.3	11.3 Resend Webhook 処理	8
1.11.4	11.4 サプレスリスト復帰フロー	9
1.11.5	11.5 DLQ 運用 (§ 11.9 から移管)	9
1.12	12. ウィジェット保護 (§ 10.2 から移管)	9
1.13	13. PII マスキング・プロンプト注入対策	9
1.13.1	13.1 PII マスキング (§ 10.7 から移管)	9
1.13.2	13.2 プロンプト注入対策 (§ 10.3 から移管)	9
1.14	14. バックアップ・復旧	10
1.15	15. 未決事項	10

1 セキュリティ設計書 (メイン)

1.1 1. 文書概要

1.1.1 1.1 目的

メインシステムのセキュリティ対策(データ保護 / 入力値検証 / Web 脆弱性対策 / アクセス制御 / 監査ログ / 秘密情報管理 / 不正利用検知 / メール配信信頼性 / ウィジェット保護 / PII マスキング / プロンプト注入対策)を一元化する。

1.1.2 1.2 対象範囲

- 対象: 利用者向けシステムのセキュリティ全般、**PII 暗号化 (共有概念正本) / 暗号鍵管理 (共有概念正本)**
- 対象外: 運営者側のハッシュチェーン監査構造・3 区分保持の物理実装 ([02_運営者システム/個別設計書群/10_セキュリティ設計書.md §7 正本](#))

1.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_索引.md
共有概念対応表	監査ログ / / PII の正本所在	../共有/共有概念.md
認証・認可設計書	認証・認可の根拠	09_認証認可設計書.md
権限設計書	アクセス制御	05_権限設計書.md
テーブル定義書	暗号化対象カラム / 監査ログテーブル	04_テーブル定義書.md
API 設計書	IF #9 不正利用検知通知	03_API 設計書.md
エラー設計書	エラー時の監査 / ログ出力	06_エラー設計書.md
運営者側 セキュリティ設計書	監査ログハッシュチェーン構造の正本	../02_運営者システム/個別設計書群/10_セキュリティ設計書.md

1.2 2. セキュリティ基本方針

1.2.1 2.1 保護対象

- 利用者の PII(メール / 名前 / 個人識別情報)
- エンドユーザー PII(メール)—— 基本設計書 §7.10 / FR-114 対象
- 認証情報 (パスワード / セッション / トークン)
- 暗号 (マスター / バックアップ / オーナー派生 / グローバル派生)
- 課金・決済情報 (Stripe 連携、カード情報は Stripe に委譲)
- 監査ログ (改ざん検知必須)

1.2.2 2.2 想定脅威

- 不正アクセス (クレデンシャルスタッフィング / ブルートフォース / R-005)
- データ漏洩 (他契約データ参照 / R-004)
- インジェクション (SQLi / XSS / プロンプト注入)
- メールレピュテーション悪化 (R-003 / 共通ドメイン使用)
- DDoS / Bot 暴走
- AI 出力経由の機密漏洩 / PII 漏洩

1.2.3 2.3 基本対策方針

- 多層防御** (認証 → 認可 → 入力検証 → 出力検査 → 監査)
- 最小権限原則** (オーナー専有 / プロジェクト別ロール `admin / member(project_users.role)` の二段階)
- 監査の網羅性** (変更系操作は全て監査、参照系は高権限操作のみ)
- 改ざん検知** (ハッシュチェーン + 完全性検証バッチ、運営者側 §7 正本)

1.3 3. データ保護

1.3.1 3.1 PII 暗号化 (AES-256-GCM)+ オーナー派生鍵 (共有概念正本 = メイン側)

(基本設計書 §10.4 + §7.10 から移管)

対象データ	暗号化方式	鍵	保存先	ログ出力
エンドユーザーメール	AES-256-GCM	オーナー派生 (deriveOwnerKey())	inquiry_contacts.email_encrypted + email_hmac(HMAC で検索用)	不可
利用者メール	AES-256-GCM	オーナー派生	users.email_encrypted + email_hmac	不可
招待トークン / 各種トークン	HMAC-SHA256	オーナー派生 / グローバル派生	直接保存しない(ハッシュのみ)	不可

1.3.2 3.2 保護層別方針

層	方式	関連
通信	HTTPS 必須	NFR-301
HSTS	Strict-Transport-Security: max-age=31536000; includeSubDomains; preload	NFR-315
パスワード	Argon2id m=64MB, t=3, p=4, salt=16B	NFR-304
トークン	HMAC-SHA256 ハッシュ保存、オーナー / グローバル派生 使い分け	NFR-305
監査ログ	最小限情報、PII 除外	FR-114 / § 10.6.5
オーナー境界	全 API で境界検証、自動テスト月次 50 ケース + 年次手動レビュー	NFR-302
個人情報マスキング	AI 出力・チャット表示で § 13 PII Scrubber 層適用	FR-060 / NFR-805
AI 学習利用禁止	AnswerProvider learn=false 強制、Workers AI ログ無効化	NFR-405
チャット本文平文保存	DB 操作者 2 名以下 + 月次棚卸し + 全クエリ監査ログ + チケット ID 必須 (4 補完策)	NFR-319

1.3.3 3.3 データ削除モード (物理削除 / 匿名化、§7.8 から移管)

オーナー設定 `data_deletion_mode`(`physical` / `anonymize`、初期値 `physical`)

対象テーブル	物理削除	匿名化
question_logs	DELETE	user_question 空字、ip_address / user_agent NULL、集計値維持
inquiries	DELETE	user_question 空字、inquiry_code 維持、closed_reason 空字
chat_messages	DELETE	content 空字、actor_type 維持
inquiry_contacts	DELETE	email_encrypted → anon_<sha256>、display_name → 「匿名」
notification_logs	DELETE	recipient_email_hmac → SHA-256、vars → 空 JSON
access_tokens	DELETE	(常に物理削除、匿名化対象外)
audit_logs	削除しない	(tombstone 方式、匿名化対象外)

担保事項:

- ・ **不可逆性**: メールアドレスハッシュ化など、原文復元不可な置換のみ
- ・ 設定管理: `contract_owners.data_deletion_mode` は契約締結時に既定 `physical`。MVP では UI 上の変更操作を提供せず、変更が必要な場合はサポート窓口経由の運営者対応とする (SCR-028 アカウント設定にデータ保持・削除モード設定 UI は持たない)
- ・ 監査: `audit_logs.action='owner.data_deletion_mode.change'`(運営者操作時、`retention_class=operator_high_priv`)

1.3.4 3.4 お知らせ二層構成 (§7.7 から移管)

二層構造:

- ・ 配信元層 (Control Plane): `service_announcements` テーブル
- ・ 配信宛先層: `announcement_recipients`(送信日時・配信失敗フラグ等、監査用)
- ・ 受信箱層 (Tenant): `inbox_messages`(管理者のアプリ内閲覧用)

種別	トリガー	二層構成経由	特記
announce	運営者がお知らせを公開 (IF #7)	service_announcements → announcement_recipients → inbox_messages	配信集計が必要
billing	月次請求確定	直接 inbox_messages	契約内で完結
system	上限接近・超過等	直接 inbox_messages	ヘッダベル+メール (high/critical)

重複生成対策 (R-012): 同一 (contract_owner_user_id, event_kind, dedup_key) で 60 分以内の複数発火は 1 件に集約

1.4 4. 入力値検証

対象	検証内容	対策する脅威	備考
API リクエスト	Zod スキーマ (詳細設計書)	入力エラー / 型混乱	全 API 必須
URL パラメータ	型強制 + 範囲チェック	パストラバーサル	-
ファイルアップロード	(MVP 範囲外)	-	Future
ウィジェット入力	エンドユーザー入力は先頭 100 文字 + ハッシュのみログ	PII 漏洩 / ログ膨張	FR-114
お知らせ本文	入稿時 + 表示時の 2 重サニタイズ	XSS	NFR-309
FAQ 質問	1~500 文字	バリデーション	FR-046
FAQ 回答	1~5,000 文字	バリデーション	FR-046

1.5 5. Web 脆弱性対策

1.5.1 5.1 HTTP 応答ヘッダ (§10.5 から移管)

Content-Security-Policy:

```

default-src 'self';
script-src 'self' 'nonce-<random>';
style-src 'self' 'nonce-<random>';
img-src 'self' data: https:;
object-src 'none';
frame-ancestors 'none';
base-uri 'self';
form-action 'self'

```

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

X-Content-Type-Options: nosniff

X-Frame-Options: DENY

Referrer-Policy: strict-origin-when-cross-origin

Permissions-Policy: camera=(), microphone=(), geolocation=()

ウィジェット側は frame-ancestors * (顧客サイト埋め込みのため)。

1.5.2 5.2 主要脅威別対策

脅威	対策	対象箇所
XSS	CSP script-src 'self' 'nonce-<random>' + 自動エスケープ + お知らせ本文 2 重サニタイズ	全画面
CSRF	Double Submit Cookie + X-CSRF-Token ヘッダ突合	全更新系 API
SQL インジェクション	プリペアドステートメント / ORM	全 DB アクセス
SSRF	外部 URL 取得時のホワイトリスト	(該当機能なし、MVP)
クリックジャッキング (管理画面)	X-Frame-Options: DENY / frame-ancestors 'none'	管理画面
クリックジャッキング (ウィジェット)	frame-ancestors を allowed_domains で制限	ウィジェット iframe

脅威	対策	対象箇所
ブルートフォース	ログイン失敗 5 回ロックアウト	SCR-001/SCR-003
HSTS	Strict-Transport-Security	全レスポンス

1.5.3 5.3 お知らせ本文サニタイズ (2 重防御)

- ・ 入稿時: 連携 IF #7 受信時にサーバ側 sanitize(許可タグ・属性ホワイトリスト)
- ・ 表示時: GET /me/announcements/{id} 時に再度 sanitize
- ・ 許可タグ: <p><div><h2-4><blockquote><pre><a><code>

1.6 6. アクセス制御

対象	制御方法	関連設計書
利用者管理画面	セッション + プロジェクト別ロール (project_users.role) + オーナー境界	09_認証認可設計書.md
ウィジェット API	API キー + 署名 + allowed_domains 検証	§ 12 / 03_API 設計書.md
連携 IF	mTLS + JWT	03_API 設計書.md § 3
監査ログ参照	プロジェクト別ロール (該当 PJ の member 以上)	05_権限設計書.md

1.7 7. 監査・ログ

(運営者側 § 7 が正本、本書はメイン側固有部分のみ)

1.7.1 7.1 ログ種別と保持目的 (§10.6 から移管)

ログ種別	対象	保持目的	保持期間
監査ログ	重要操作 (認証 / 認可境界 / 状態変更 PO 機能 / 課金 / 連携 IF / データ削除復元 / 一括操作 / セキュリティ運用 / DB 直接クエリ)	監査・不正対応	§ 7.9(1y/5y/7y、general/billing/operator_high_priv)
エラーログ	例外・障害	運用確認	180 日
通知ログ	メール送受信	配信状態追跡	1 年
アクセスログ	API 呼出	分析・不正検知	90 日

1.7.2 7.2 メイン側の監査対象操作 (§10.6.5 から移管)

カテゴリ	action 例	retention_class
認証関連	auth.login_success / login_failed / locked / unlocked / re_auth / password_change / token_issued / revoked	general
認可境界	<resource>.<verb>.by_operator	operator_high_priv
状態変更 PO 機能	faq.create / update / publish / delete、case.close、member.invite / activate / disable / delete	general
課金関連	billing.invoice.issued、payment.success/failure、subscription.created/cancelled、owner.suspend/resume	billing
連携 IF	integration.if1.received、integration.if10.forwarded	general(内容に応じて operator_high_priv も)
データ削除復元	data.delete.execute、<resource>.restore.by_operator、audit_log.tombstone	operator_high_priv
一括操作	inbox.read.bulk、faq.bulk_status_change、data.export	general

カテゴリ	action 例	retention_class
セキュリティ運用	key.rotation、webhook.signature_failed、abuse.detection_fired	operator_high_priv
DB 直接クエリ	db.query.execute(操作者 / クエリ / 実行時刻 / 件数記録)	operator_high_priv

1.7.3 7.3 改ざん検知方式 (NFR-306)

詳細は運営者側 [10_セキュリティ設計書.md §7](#) を正本とする。本書では概要のみ:

- ハッシュチェーン実装: 各行に prev_hash(直前行の current_hash) と current_hash(SHA-256(id, contract_owner_user_id, actor_user_id, action, target_type, target_id, payload, created_at, prev_hash))
- 日次ダイジェスト保管: JST 03:00 に当日分最終 current_hash 抽出 + HMAC-SHA256 署名 + R2 へ書き出し
- IP マスク: IPv4 末オクテット 0、IPv6 末 80 ビット 0

1.7.4 7.4 エラーログ (error_logs)

- 180 日保持 (JST 05:00 Cron で自動物理削除、UC-140)
- スタックトレース / リクエスト ID を記録
- PII / トークン / カード情報を記録禁止 (FR-114)
- 入力値ログ: 先頭 100 文字 + SHA-256 ハッシュのみ
- カテゴリ C の 5xx 系エラーは利用者にエラー ID を提示 (FR-113)

1.8 8. 秘密情報管理 (共有概念正本 = メイン側)

1.8.1 8.1 暗号鍵管理 (§10.9 から移管)

鍵種別	保管場所	用途	ローテーション周期
Master Key	Cloudflare Secrets Store	オーナー派生 ・ グローバル派生 のベース	年次
オーナー派生	動的生成 (HKDF-SHA256, info=owner:<id>)	エンドユーザーメール暗号化 ・ トークン HMAC	Master Key 更新時に再 KDF
グローバル派生	動的生成 (HKDF-SHA256, info=global)	パスワードリセット ・ API キー生成	Master Key 更新時に再 KDF
API キー	動的生成 ・ 管理者操作で選択	ウィジェット公開キー (pk_live_<32-char base62>)	7 / 30 / 90 / 180 / 365 日選択 (無期限不可)
Backup Key	別管理 (Master Key と分離)	復旧用 (AES-256-GCM 暗号化)	年次ローテーション (NFR-324)

1.8.2 8.2 ローテーション運用

操作	方式
Master Key ローテーション中	60 日 dual-decrypt(旧 と新 の両方で復号を試行)(NFR-321)、MVP ハードゲート 4-eyes 対象(要件 §6.2.3)
API キーローテーション猶予	30 日 (FR-193)、SCR-014 に「旧キー使用中」バッジ表示
外部プロバイダ API キー (Resend / Stripe)	Workers Secrets Store 保管、90 日ローテーション を目標 (NFR-323)
漏洩検知時	(a)Secrets Store 即時ローテーション、(b)該当プロバイダ管理画面から旧キー revoke、(c)影響契約へ inbox/high 通知、(d)全運営者 ・ 管理者セッション無効化

1.8.2.1 8.2.1 鍵バージョン参照 dual-decrypt 期間中に「どのレコードがどの世代の で暗号化されているか」を明示するため、PII 暗号化列を持つテーブルに email_key_version INTEGER NOT NULL DEFAULT 1 を保持する。

対象テーブル	カラム	説明
users	email_key_version	オーナー / メンバーのメールアドレス暗号化バージョン
inquiry_contacts	email_key_version	案件連絡先メールアドレス暗号化バージョン

運用フロー:

1. INSERT / UPDATE 時: アプリは最新 バージョン (Secrets Store の **email_key_active_version** から取得) で暗号化し、その値を **email_key_version** に記録する
2. SELECT 時: 復号処理は **email_key_version** を読み取り、対応する を Secrets Store から取得して復号する。dual-decrypt 期間中は version N と N-1 の両方を保持し、ヒットした方を採用する
3. ローテーション完了後: バッチで **email_key_version < N** の行を新 で再暗号化 (UPDATE ... SET **email_encrypted= 新値, email_key_version=N**)
4. 全行再暗号化完了後: 旧 を Secrets Store から削除

ローテーション完了の判定: SELECT COUNT(*) FROM users WHERE email_key_version < N が 0 件、かつ SELECT COUNT(*) FROM inquiry_contacts WHERE email_key_version < N が 0 件であること。

例外: contract_owners.contract_status='deleted' または users.valid=0 の論理削除済み行は、90 日経過後の物理削除バッチに任せ、再暗号化対象外とする (復元時の dual-decrypt 整合性を維持するため、ローテーション期間は 60 日 + 物理削除遅延 90 日を考慮した運用窓設計とする)。

1.8.3 8.3 ウィジェット API キー (projects / project_legacy_keys、§8.3.4 から移管)

- ・形式: pk_live_<32-char base62>
- ・有効期限: 7 / 30 / 90 / 180 / 365 日選択
- ・ローテーション: 旧キー 30 日併存
- ・旧キー使用検知: SCR-014 に警告バッジ + 件数 + 最終アクセス時刻

1.9 9. SaaS 特有のセキュリティ観点

観点	対策	関連設計書
オーナー間データ漏洩防止	全テーブルに contract_owner_user_id + API 層でオーナー境界判定 (404 偽装) + 自動テスト (基本設計書 §14.3、月次 50 ケース)	04_ テーブル定義書.md / 09_ 認証認可設計書.md
管理者権限の濫用防止	監査ログ全件 + プロジェクト別ロール (admin / member) の最小化 + オーナー専有機能の project_users.role 付与不可 (プロジェクト作成・編集・削除・課金・退会・規約再同意はオーナー専有。メンバーアカウント物理削除はオーナーおよび当該プロジェクト管理者だが、プロジェクト管理者は member 在籍中は他 admin を削除不可)	05_ 権限設計書.md / §7
契約停止中の利用制御	contract_status=suspended で課金 / 退会 / データエクスポートのみ許可	09_ 認証認可設計書.md §6 / 11_ 課金請求設計書.md §5
支払い情報の取り扱い	カード情報は Stripe に委譲、自システムでは保持しない	11_ 課金請求設計書.md §11
連携 IF の改ざん防止	mTLS + JWT + ペイロード SHA-256 (運営者側 Web-hook 差分検出と連携)	03_API 設計書.md §3.4

1.10 10. 不正利用検知 (基本設計書 §10.10 / FR-195 / NFR-308 = 共有概念正本)

1.10.1 10.1 検知・対応体系

観点	仕様
検知ロジック	メインシステム側で実装 (FR-195(a))
しきい値	IF #5 / #6 経由で契約別に上書き可能 (FR-195(b))。初期値は要件 FR-055 / FR-061
自動ブロック	レート制限緊急引き下げ・契約 suspended 遷移をメインシステム側で実行 (FR-195(c))
通知	自動ブロック発火時、管理者ユーザーへ inbox(system/high) + email 即時通知、申し立て窓口案内 (FR-195(d) / NFR-317)
運営者手動停止	顧客管理 FR-224 から実行 (IF #1 経由)

観点	仕様
監査	audit_logs.action='abuse.detection_fired'(retention_class='operator_high_priv')

1.10.2 10.2 検知パターン

検知パターン	検知ロジック	アクション	関連 IF
異常リクエスト	Rate limit 突破 / 異常パス	レート制限強化 + 運営者通知	IF #9
メール bounce 多発	bounce 率しきい値超過	サプレスリスト追加 + 運営者通知	§ 11
不正ログイン	同一 IP 多数 user_id ロックアウト	IP 単位ブロック + 運営者通知	IF #9
プロンプト注入試行	§ 13.2 検出パターン	ブロック + 監査 + 運営者通知	IF #9

1.11 11. メール配信信頼性・レピュテーション保護

(基本設計書 § 9.2 / § 9.3 / R-003 / FR-149b から移管)

1.11.1 11.1 メール配信信頼性 (NFR-501~507)

項目	方針
送信	API 同期処理に含めず Queue 経由 (NFR-507)
一時失敗時の自動再送	Queue Consumer による自動再送 (指数バックオフ)、最大 3 回、最大遅延 24 時間
Resend 自動再送	email.delivery_delayed で Resend が裏で再送中。当方の再送カウンタに含めない (NFR-506)
バウンス	Resend Webhook 検知、対象アドレスを通知停止 (email_suppression_list 追加)
苦情	Resend Webhook 検知、即時永久サプレス (復帰不可)
監視	契約別レート・バウンス率・苦情率をしきい値監視 (NFR-804)
サンドボックス	開発・検証環境は Resend サンドボックス使用
冪等性	event_id で重複処理を防止 (NFR-505)
DLQ	Cloudflare Queues DLQ、1 時間以内に運営者へアラート (NFR-507)

1.11.2 11.2 共通ドメインレピュテーション保護 (R-003 / FR-149b / NFR-504)

項目	方針
送信レート制限	契約別時間あたり通数の上限設定 (運営者調整可、IF #5)
バウンス率監視	しきい値超過時にアラート / 送信抑制
苦情率監視	同上
件名・本文	エンドユーザー入力をそのまま使わない (FR-145、なりすまし対策)
通知停止	バウンス・苦情・オプトアウトの即時反映
異常検知	短時間急増・未配信率急上昇を運営者に通知
全契約横断サプレス	email_suppression_list を全契約横断で共有 (FR-149b)
復帰承認	サプレスリスト復帰承認は運営者の SCR-093 経由 (顧客管理基本設計 § 9.4)

1.11.3 11.3 Resend Webhook 処理

イベント	処理
email.sent	notification_logs.delivery_state='sent'
email.delivered	delivery_state='delivered'
email.bounced(hard)	サプレス + 管理者ユーザー inbox 通知
email.bounced(soft)	カウンタ +1、5 回でサプレス
email.complained	即時永久サプレス + 運営者 high 通知
email.delivery_delayed	Resend 側自動再送待機、24h 後も未配信なら当方カウンタ +1
email.opened/clicked	集計のみ (個人特定なし)
署名検証失敗	即時破棄 + 運営者 high 通知 (NFR-310)

1.11.4 11.4 サプレスリスト復帰フロー

イベント	アクション	復帰方法
ハードバウンス	即時サプレス、全契約横断共有	SCR-015「再有効化申請」→ 運営者承認 (IF #5)→ 復帰
ソフトバウンス 5 連続	サプレス、全契約横断共有	同上
苦情 (complaint)	即時永久サプレス	復帰不可
レピュテーション低下警告	契約送信レート -50%(IF #5)	24h 経過 + バウンス率 <1% で自動復帰

1.11.5 11.5 DLQ 運用 (§11.9 から移管)

項目	仕様
DLQ 保持期間	4 日間 (Cloudflare Queues 現行制限値)。超える保持が必要なイベント → R2 にコピー保存
自動再処理	DLQ 投入から 1 時間以内 は自動指数 BO 再試行、それ以降は運営者の明示的リプレイ操作のみ (SCR-097)
リプレイ範囲	直近 30 日 (R2 回避分を含む)。30 日超は不可
DLQ 監視	DLQ 滞留が § 8.7.2 の IF 別上限値を超えた瞬間に運営者 high 通知 + メール
署名検証失敗	即時破棄 + 運営者 high 通知 (NFR-310)

1.12 12. ウィジェット保護 (§10.2 から移管)

項目	方式
許可ドメイン検証	Origin / Referer で判定、完全一致 + *.example.com ワイルドカード
CORS	許可ドメインのみ、Access-Control-Max-Age=600
API 署名	公開キー (pk_live_<32-char base62>)+ セッショントークン組み合わせ認証
iframe sandbox	sandbox="allow-scripts allow-forms allow-same-origin allow-popups"(allow-top-navigation なし)
CSP	default-src 'self' https://api.<service>; script-src 'self'; frame-ancestors *
レート制限	プロジェクト / IP / セッション単位 (IF #5 で運営者調整可)
Bot 対策	Turnstile を必要に応じて適用 (FR-177)
入力制限	文字数 2,000、連続送信 (EU 10 件/分)、危険文字列無害化
プロジェクト単位 IP 許可リスト (FR-179 / FR-330)	project_ip_allowlist を参照し、/widget/v1/* 配下を IP CIDR で制限。空 = 制限なし。設定 UI は SCR-010-M1、評価仕様は 02_API 設計.md § 5.5.0、判定式・キャッシュは 08_認証・認可設計.md § 5.6 正本。管理画面 API は本設定の評価対象外 (誤設定時の自己ロックアウトを発生させないため)

1.13 13. PII マスキング・プロンプト注入対策

1.13.1 13.1 PII マスキング (§10.7 から移管)

観点	方針
検出器配置	Cloudflare ネットワーク内 (Workers AI + 正規表現ルール)、外部 API 送信不可
検出ルール保守	KV に保持、運営者システム (SCR-098) で更新可能
監査記録	マスキング発動: audit_logs.action='ai.pii_masked'、検査 NG: ai.output_inspection_failed(マスク前データ非記録)
誤検出改善ループ	管理者ユーザーが「誤検出」報告 → SCR-098 に集約 → 検出ルール改善 (AC-036、3 営業日以内判定)

1.13.2 13.2 プロンプト注入対策 (§10.3 から移管)

対策	内容
FAQ 限定ポリシー固定	サーバ側でシステム指示を固定 (§ 6.4.4)、クライアント上書き不可
候補なし時	AI 生成へ進まない
出力検査	参照 FAQ 外の要素を検出 (§ 6.4.2)
不審入力検知	命令上書き等を検知・記録 (audit_logs.action='ai.prompt_injection_detected')
失敗時	安全側に倒し未解決登録または安全エラー
2 段階テスト	社内 100+ ケース 95% × 必須 20 ケース 100%(AC-019 × AC-035)

1.14 14. バックアップ・復旧

(運用詳細は [03_運用/運用手順書.md](#) 参照)

項目	仕様
D1 バックアップ	Cloudflare 自動バックアップ (時間単位)
R2 バックアップ	バージョンング有効、削除はソフトデリート
復旧目標	RPO 1 時間 / RTO 4 時間
災害時手順	RB-021(メイン障害時の運営者側縮退運転)

1.15 15. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------